

Individuell examineringsuppgift – MITRE ATT&CK

Namn: Abdulelah Hanoun

Del 1 – MITRE ATT&CK

1. MITRE ATT&CK används för att beskriva och analysera angripares beteenden. Det ger säkerhetsteam ett gemensamt språk och hjälper dem att planera upptäckt, skydd och uppföljning.

2. ATT&CK är ett analysramverk och inte en instruktion för att genomföra attacker. Det ska användas för att förstå hot och förbättra försvar, inte som en checklista för angrepp.

3.

- Initial Access: första åtkomst till miljön.
- Execution: något körs i miljön.
- Persistence: åtkomst behålls.
- Discovery: information om system och konton samlas in.
- Impact: verksamheten påverkas eller störs.

4. ATT&CK ger red team, blue team och ledning ett gemensamt språk. Red team kan beskriva testade beteenden, blue team kan visa vad som upptäcktes och ledningen kan prioritera åtgärder utifrån risk. Det gör arbetet mer tydligt och spårbart.

Del 2 – TTP

5. Tactic är angriparens mål. Technique är typen av beteende. Procedure är hur beteendet syns i ett specifikt fall. Exempel: Initial Access är tactic, Phishing är technique och ett misstänkt mejl är procedure.

6.

Tactic	Technique	Procedure
Initial Access	Phishing	Misstänkta meddelanden riktas mot användare.
Credential Access	Valid Accounts	Ett konto används från ovanlig plats eller tid.
Discovery	Account Discovery	Ovanlig aktivitet söker information om konton.

7. Jag väljer Discovery. Account Discovery, System Information Discovery och Network Service Scanning passar eftersom de används för att samla information om konton, system och tjänster.

8. Mappning kan vara svår eftersom samma observation kan ha flera orsaker. En ovanlig inloggning kan vara ett angrepp eller legitimt arbete. Därför behövs rätt kontext, bra loggar, relevanta källor och dokumenterade osäkerheter.

Del 3 – Defensiv attackkedja

9 och 12.

Initial Access → Credential Access → Discovery → Persistence → Impact

Exempel: phishing → användning av konto → kartläggning av system → ändrade behörigheter → störning av verksamheten.

10.

Steg	Syfte och observation
-------------	------------------------------

Phishing: Få första åtkomst. Misstänkta meddelanden syns.

Valid Accounts: Använda ett konto. Ovanliga inloggningar syns.

Discovery: Samla information. Aktivitet mot flera system syns.

Persistence: Behålla åtkomst. Konto eller behörighet ändras.

Impact: Påverka verksamheten. Filer eller tjänster blir otillgängliga.

11. De mest osäkra stegen är Valid Accounts och Persistence. Vi behöver kontrollera om inloggningarna och kontoändringarna var godkända samt om loggarna är tillräckliga.

Del 4 – Försvar

13.

- Kan misstänkta meddelanden upptäckas och rapporteras?
- Kan ovanliga inloggningar upptäckas?
- Finns loggar över konto- och systemaktivitet?
- Kräver behörighetsändringar godkännande?
- Finns säkerhetskopior och återställningsrutiner?

14. För Phishing är misstänkta avsändare, länkar och användarrapporter viktiga signaler. För Valid Accounts är ovanliga platser, tider, enheter och flera misslyckade inloggningar relevanta signaler.

15. Phishing kan minskas med utbildning, filtrering och tydlig rapportering. Missbruk av konton kan minskas med multifaktorauslösningsrutiner, minsta behörighet och regelbundna kontroller av konton.

16. Attackkedjan visar hur flera händelser kan höra ihop. Den hjälper teamet att hitta svaga delar i försvaret och prioritera rätt åtgärder. Den kan även användas för att följa upp om nya detektioner, rutiner och kontroller fungerar.

Del 5 – Källor och kvalitet

17. Källor

- MITRE ATT&CK – information om tactics och techniques:
<https://attack.mitre.org/>
- Enterprise Matrix – översikt över attackkedjan:
<https://attack.mitre.org/matrices/enterprise/>
- CISA – vägledning för ATT&CK-mappning:
<https://www.cisa.gov/news-events/news/best-practices-mitre-attckr-mapping>
- Kursmaterial och anteckningar från Workshop 2 och 3.

18. Vi jämför observationer med MITRE ATT&CK, skriver en motivering och kontrollerar källorna. Osäkerheter dokumenteras och en annan gruppmedlem granskar resultatet.

19. Definition of Done

- Attackkedjan är tydlig.
- Tactics och techniques är angivna.
- Källor och motiveringar finns.
- Försvarsfrågor är besvarade.
- Osäkerheter är dokumenterade.
- Resultatet är kopplat till backloggen.
- En annan person har granskat analysen.

20. En användbar hotanalys är tydlig, spårbar och begriplig för andra. Den visar källor, antaganden, osäkerheter och rekommenderade åtgärder. Den ska kunna användas av både tekniker och projektledning.

Del 6 – Backlog och sprint

21. Nya backlog items

- Kontrollera loggar för ovanliga inloggningar.
- Skapa rutin för phishing-rapportering.
- Granska användarkonton och behörigheter.
- Dokumentera attackkedjan.
- Kontrollera vilka delar av kedjan som kan upptäckas.

22. Attackkedjan stödjer vårt Sprint Goal eftersom den visar vilka säkerhetsproblem vi ska fokusera på. Sprintmålet är fortfarande relevant, men bör kompletteras med bättre loggning, behörighetskontroll och dokumentation.

23. Uppföljningsfrågor

- Vilka delar av attackkedjan kan vi upptäcka idag?
- Vilka åtgärder ska prioriteras i nästa sprint?
- Vilka delar behöver mer information?

24. Status inför Workshop 3

- Vi har skapat en attackkedja.
- Vi har kopplat den till ATT&CK.
- Vi har identifierat möjliga detektionssignaler.
- Vi har föreslagit riskreducerande åtgärder.
- Källor och osäkerheter är dokumenterade.
- Loggar och nuvarande kontroller behöver undersökas.
- Nästa steg är att prioritera backloggen.

AI-användning

Jag använde en AI-assistent för att strukturera och förenkla texten. Jag kontrollerade innehållet mot MITRE ATT&CK, CISA och kursmaterialet och gjorde själv bedömningar av attackkedjan och backloggen.